

Phishing y fraude por correo (BEC)

Cómo reconocer y bloquear los dos fraudes por correo que más dinero cuestan a las pymes: el phishing (robo de credenciales) y el BEC (Business Email Compromise: el fraude del cambio de cuenta bancaria y el fraude del CEO). Incluye el procedimiento de doble aprobación listo para implantar esta misma semana.

1. Qué está pasando

En el BEC, el atacante no rompe nada: convence. Suplanta a un proveedor, a un directivo o a un cliente y pide algo que parece rutinario — pagar una factura, cambiar un número de cuenta, hacer una transferencia urgente. No hay malware que detectar; solo un correo creíble y prisa. Por eso los controles técnicos solos no bastan: hace falta un procedimiento que no dependa de que nadie tenga un mal día.

2. Señales de alerta

- Cambio de cuenta bancaria comunicado por correo, sobre todo de un proveedor habitual.
- Urgencia y confidencialidad: «es para hoy», «no llames, estoy en una reunión».
- Dominio parecido pero no idéntico (proveedor.com vs proveedor-es.com).
- Responder a (Reply-To) distinto de la dirección que aparece como remitente.
- Solicitud que salta el procedimiento normal o que pide saltárselo.
- Tono o petición inusual en quien escribe, aunque el nombre sea correcto.

3. Anatomía de un fraude de cambio de cuenta

Recibes un correo de «tu proveedor» adjuntando una factura idéntica a las de siempre. Solo cambia una cosa: el IBAN. El correo viene de una dirección casi igual a la real — o de la real, comprometida. Si nadie llama al proveedor por un teléfono ya conocido para confirmar, el siguiente pago se va a la cuenta del atacante — y no se detecta hasta que el proveedor de verdad reclama.

4. El procedimiento de doble aprobación (implementalo hoy)

Aplicalo a (a) toda transferencia por encima del umbral que definas y (b) cualquier cambio de datos bancarios de un proveedor o empleado, sin importe mínimo.

Paso 1 — Verificación por canal alternativo

Confirma la petición por un canal distinto al correo y con un contacto que ya tenías (no el teléfono que aparece en el correo nuevo). Una llamada al número de siempre basta.

Paso 2 — Doble aprobación

Toda orden de pago o cambio de cuenta la aprueban dos personas distintas. Quien la solicita no puede ser quien la aprueba.

Paso 3 — Registro

Deja constancia de quién verificó, cuándo y por qué medio. Una hoja compartida es suficiente.

Paso 4 — Pausa ante la urgencia

La urgencia es la herramienta del atacante. Una solicitud urgente que rompe el procedimiento es motivo para detenerse, no para acelerar.

5. Si crees que habéis picado

- Si fue una transferencia: llama al banco de inmediato para intentar revocarla.
- Si alguien metió su contraseña: cámbiala, cierra todas las sesiones y revisa las reglas de reenvío del buzón.
- Conserva correos y registros como evidencia. No borres nada.
- Notifica internamente y, si hay datos personales afectados, valora la comunicación a la AEPD (72 h).
- Pide ayuda: INCIBE (017) y tu proveedor de ciberseguridad.

6. Defensas técnicas que reducen el riesgo

Marca las que ya tengas implantadas

☐	SPF, DKIM y DMARC configurados (DMARC al menos en p=quarantine). [Correo]
☐	Etiquetado visible de los correos externos a la organización. [Correo]
☐	MFA en todas las cuentas de correo. [Identidad]
☐	Alertas ante la creación de reglas de reenvío automático. [M365/Workspace]
☐	Lista de proveedores con datos bancarios verificados y contacto de confianza. [Proceso]

¿Quieres que lo hagamos contigo?

Q-Mail Shield deja SPF, DKIM y DMARC bien desplegados y el procedimiento anti-BEC firmado por dirección — desde 950 €, en 1-2 semanas. Y Q-Phishing Drill entrena a tu equipo con simulaciones mensuales desde 290 €/mes. — qerub.com · info@qerub.com